

TEMPLATE REPORTE EJECUTIVO GQM + PRAGMATIC

Presentación Junta Directiva (12 slides)

Versión: 2.0 | **Fecha:** Enero 2026 | **Nota:** Estructura PowerPoint descargable

SLIDE 1: PORTADA

EVALUACIÓN INTEGRAL INDICADORES CRM
GQM + PRAGMATIC Framework

Índice Global Madurez (IGM): 2.38
PRAGMATIC Score (KPIs): 4.3/5.0
Compliance Status: YELLOW (gaps DORA/NIS2)

[Logo Organización]

Fecha: Enero 2026
Clasificación: Confidencial - Junta Directiva

SLIDE 2: EXECUTIVE SUMMARY (1 página)

Contenido

SITUACIÓN ACTUAL (Baseline 2024)

✓ FORTALEZAS:

- IGM 2.38 → sobre median España (2.40)
- PRAGMATIC KPIs 4.3/5.0 → métricas viables
- Gobernanza estructurada (RAS, CISO CEO)
- Compliance GDPR 85% → manejable

x DEBILIDADES CRÍTICAS:

- DORA Compliance 70% (sector financiero: CRÍTICO)
- NIS2 Readiness 60% (españa Q1 2026: RIESGO)
- MTTD 48h (target 30 min): -60% vs benchmark
- Cuantificación FAIR: solo 40% riesgos cuantificados



INDICADORES TOP PRIORITY:

1. MTTD/MTTR (SOC effectiveness) – PRAGMATIC 4.7/5
2. Patch % <7d (vulnerability management) – 4.6/5
3. DORA Compliance (financial sector) – 3.8/5
4. Phishing Click Rate (human risk) – 4.3/5



IMPACTO FINANCIERO:

Current ALE: €8.2M/año
Post-Investment: €4.8M/año
Savings: €3.4M (41% reduction)
Investment 12m: €680K
ROI: 574% | Payback: 1.4 meses



RECOMENDACIÓN:

Aprobar inversión €680K | Timeline 12 meses |
Quick Wins Q2 | Strategic Q3-Q4

SLIDE 3: GQM FRAMEWORK VISUAL

Diagrama Jerárquico

NIVEL 1: STRATEGIC GOALS (Nacional España)

- G1: Gobernanza (junta oversight)
- G2: Cuantificación (€ decisions)
- G3: Threat Modeling (operacional)
- G4: Detección rápida (MTTD <30 min)
- G5: Respuesta eficiente (MTTR <4h)
- G6: Vulnerabilidades (patching <7d)
- G7: Supply Chain (auditoría)
- G8: Awareness (human risk)
- G9: Compliance (GDPR/DORA/NIS2)
- G10: Automatización (Policy-as-Code)

↓ (REFINED BY)

NIVEL 2: OPERATIONAL QUESTIONS

- "¿Cuál es IGM actual?"
- "¿MTTD vs benchmark?"
- "¿Gaps DORA/NIS2?"

↓ (MEASURED BY)

NIVEL 3: TECHNICAL METRICS

- IGM Score (0-4.0)
- MTTD (minutos)
- Compliance % (0-100%)
- ROI (%)

SLIDE 4: PRAGMATIC EVALUATION MATRIX

Tabla: Top KPIs Calificados

KPI	GQM Goal	P	R	A	G	M	A	T	I	C	Score	Status
MTTD	G4	5	5	5	5	5	5	5	4	4	4.7	√√√
MTTR	G5	5	5	5	5	5	4	5	4	5	4.6	√√√
Patch %	G6	5	5	5	5	5	4	4	4	4	4.6	√√√
Phishing	G8	4	5	5	4	5	4	4	4	3	4.3	√√
RAS	G1	3	5	4	5	4	4	5	5	5	4.4	√√
ALE	G2	4	5	5	3	5	3	3	4	2	3.9	√

Criterios PRAGMATIC:

P=Predictivo, R=Relevante, A=Accionable, G=Genuino, M=Significativo, A=Preciso, T=Oportuno, I=Independiente, C=Rentable

SLIDE 5: COMPLIANCE SCORECARD

Status Regulatorio

COMPLIANCE DASHBOARD			
REG.	COMPLIANCE %	SANCIONES	STATUS
GDPR		85% €1-5M	● YELLOW
DORA*		70% €5-10M	● RED
NIS2 Pre		60% €10M pot	● RED

* DORA aplicable si sector financiero

** NIS2 deadline españa Q1 2026

ACCIONES INMEDIATAS:

1. DORA: RTO/RPO <4h validation → Q1 2026
2. NIS2: Gap assessment + roadmap → Q2 2026
3. GDPR: Cierre 15% gaps → Q2 2026

SLIDE 6: KPI PERFORMANCE vs TARGET

Gráfico: Actual vs Benchmark vs Target

	ACTUAL	BENCHMARK	TARGET
MTTD	▼ 48h 	▼ 30 min 	▼ 30 min 
MTTR Critical	▼ 7h 	▼ <4h 	▼ <4h 
Patch %	▼ 92% 	▼ 95% 	▼ 95% 
Phishing	▼ 8% 	▼ <5% 	▼ <5% 
IGM Score	▼ 2.38 	▼ 3.86 	▼ 3.50 

Leyenda:  = Actual |  = Gap to Target

SLIDE 7: GQM ↔ PRAGMATIC INTEGRATION

Ejemplo: Métrica MTDD

GQM MAPPING:

Goal G4: "Detectar incidentes rápidamente"

Question: "¿MTDD <30 min vs 48h actual?"

Metric: MTDD = timestamp detection - timestamp incident

PRAGMATIC EVALUATION:

P=Predictivo (5/5): MTDD ↓ = damage ↓ (IBM data)

R=Relevante (5/5): DORA Art 19 exige

A=Accionable (5/5): IF MTDD >1h THEN escalate

G=Genuino (5/5): Timestamp objective

M=Significativo (5/5): Cada 10 min = €500K+ saved

A=Preciso (5/5): Log timestamp clear

T=Oportuno (5/5): Real-time dashboard

I=Independiente (4/5): Mild MTTR dependency

C=Rentable (4/5): <€5K SIEM setup

PRAGMATIC SCORE: 4.7/5 ✓✓✓ EXCELENTE

CONCLUSIÓN: Métrica CORE; implementación ASAP

SLIDE 8: FINANCIAL IMPACT & ROI

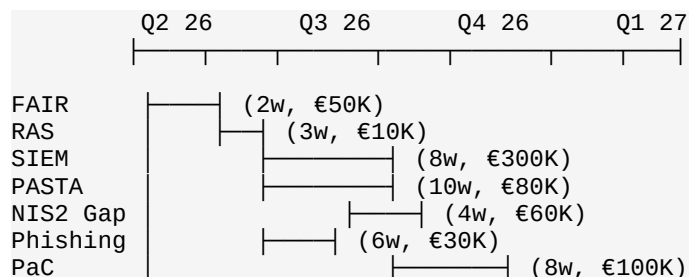
Tabla: Control Investment Analysis

CONTROL Payback	Current ALE	Reduction	New ALE	Savings	Cost	ROI	
SIEM + SOAR	€1.5M	60%	€0.6M	€0.9M	€300K	300%	4.0m
EDR	€5.0M	40%	€3.0M	€2.0M	€200K	900%	1.2m
FAIR Framework	Varies	15% dec.	Varies	€0.75M	€50K	1400%	0.4m
Phishing Prog.	€0.8M	50%	€0.4M	€0.4M	€30K	1233%	0.9m
Vendor Audit	€2.0M	30%	€1.4M	€0.6M	€100K	500%	2.0m
TOTALES	€9.3M	~40%	€5.4M	€3.9M	€680K	574%	1.4m

NPV 5-YEAR (8% discount): €15.2M

SLIDE 9: ROADMAP TIMELINE (12-24 MESES)

Gantt Visual



TOTAL: €680K over 12 months

Aggregate ROI: 574%

SLIDE 10: GOVERNANCE DECISIONS REQUIRED

3 Decisiones Críticas

DECISIÓN 1: Presupuesto Aprobación

- Monto: €680K (presupuesto formal)
- Timeline: 12 meses (fases Q2-Q1)
- Owner: CFO (financiero) + CISO (ejecución)
- Expected ROI: 574% | Payback 1.4m
- ☐ Aprobado ☐ Condicionado ☐ Rechazado

DECISIÓN 2: Governance Accountability

- RAS formal documento (junta firma)
- Risk Tolerance umbrales (operacional)
- CISO reporting CEO (línea directa)
- Board visibility trimestral (KPI dashboard)
- ☐ Aprobado ☐ Condicionado ☐ Rechazado

DECISIÓN 3: Compliance Readiness

- DORA: 70% → 100% by Sept 2026 (financial)
- NIS2: 60% → 90% by Q1 2027 (españa)
- GDPR: 85% → 95% by Q2 2026
- Auditor external? (BdE, CNMV, INCIBE)
- ☐ Aprobado ☐ Condicionado ☐ Rechazado

SLIDE 11: RISKS & MITIGATIONS

5 Riesgos de Implementación

RIESGO 1: Talent Shortage (Probability: 60%)

- ─ Impacto: €80K costo extra; timeline +6w
- ─ Mitigación: Contrata junior + training interno
- ─ Owner: HR

RIESGO 2: Technology Integration (40%)

- ─ Impacto: SIEM-legacy system delays
- ─ Mitigación: POC phase (4w) antes deployment
- ─ Owner: IT Director

RIESGO 3: Regulatory Changes (50%)

- ─ Impacto: NIS2 transposición requirements differ
- ─ Mitigación: Flexibility 30% roadmap buffer
- ─ Owner: Compliance

RIESGO 4: Budget Constraints (25%)

- ─ Impacto: Presupuesto reduced; timeline extended
- ─ Mitigación: Phase approach; Quick Wins first ROI
- ─ Owner: CFO

RIESGO 5: Stakeholder Resistance (30%)

- ─ Impacto: CISO change management + board skepticism
- ─ Mitigación: Early communication; ROI clarity
- ─ Owner: CISO

SLIDE 12: NEXT STEPS (30-90 DÍAS)

Action Plan Inmediato

SEMANA 1-2: APPROVAL & SETUP

- Junta aprueba presupuesto + roadmap
- Designar project leads per iniciativa
- Formar steering committee (CISO, CFO, IT)

SEMANA 2-4: QUICK WINS KICKOFF

- Publicar RFP FAIR consulting
- Initiate SIEM POC (4 weeks)
- Lanch phishing program (baseline)

SEMANA 4-8: STRATEGIC INICIATIVES

- FAIR assessment (2 weeks, consultant)
- SIEM vendor selection
- NIS2 gap analysis begin

SEMANA 8-12: DEPLOYMENT COMIENZA

- SIEM implementation team
- Policy-as-Code pilots
- Training comienza

Q2 2026 END-STATE:

- ✓ MTTD improving (SIEM live)
- ✓ FAIR models built (€ decisions enabled)
- ✓ Phishing trending down (awareness active)
- ✓ DORA/NIS2 gaps identified + roadmap

OWNER: CISO (Project Lead)

CADENCE: Weekly steering committee; monthly board update

CONCLUSIÓN / CIERRE

RESUMEN (3-LINER):

1. Madurez CRM 2.38/4.0 → viable mejora con inversión
2. 10 KPIs PRAGMATIC 4.3/5.0 → indicadores accionables
3. €680K → €3.4M savings → 574% ROI → 1.4 month payback

RECOMENDACIÓN:

- ✓ APROBAR roadmap 12 meses
- ✓ COMENZAR Q2 2026 (Quick Wins)
- ✓ MONITOR KPIs trimestralmente

PREGUNTAS & DISCUSIÓN

Fin Template PowerPoint